

CO4 -
ASSESSMENT
TOOL - 3

Name : C. Prathibha

Reg. NO : 192424293

Course code : ITA1408

Course Name : Ethical Hacking

1. Web Server and web application security:

The e-commerce company may be facing attacks because of an outdated apache server, poor input validation, hidden directories, and in absence of a WAF.

Attack vectors:

- ⇒ Outdated Apache may contain known vulnerabilities.
- ⇒ Hidden directories and files may expose sensitive information.
- ⇒ Poor input validation can lead to SQL injection and XSS.
- ⇒ Weak authentication / session management can result in account takeover.
- ⇒ Absence of WAF allows malicious HTTP requests to reach the application.

Kali Linux Methodology:

1. **Reconnaissance:** use NMAP to identify open ports and services. whatweb can identify web technologies.
2. **Scanning:** use Nikto to identify web-server weaknesses and misconfigurations.
3. **Directory Discovery:** Gobuster can identify publicly accessible directories.
4. **Web testing:** Burp suite can inspect and modify HTTP requests.

5. **Validation**: vulnerabilities should be safely verified only in an authorized testing the environment.

Defense:

- ⇒ Update Apache and all software regularly.
- ⇒ use input validation & parameterized queries.
- ⇒ Disable unnecessary services and directory listing.
- ⇒ Implement secure authentication and session management.
- ⇒ Deploy a WAF, firewall, and IDS/IPS.

Conclusion:

Regular patching, secure coding, WAF protection, monitoring and server hardening provide defense-in-depth.

2. **SQL Injection and XSS**

The financial application is vulnerable because user input is not properly validated or encoded.

SQL Injection:

SQL Injection occurs when malicious input changes the intended database query. It can allow unauthorized access to sensitive customer information or modification of database records.

XSS:

XSS occurs when malicious user input is displayed in a webpage without proper output

encoding. Stored XSS can affect other users who view the infected page.

Testing method :

1. Use Burp suite to capture and inspect application requests.
2. Identify login, search, and other user-controlled parameters.
3. Test parameters with safe inputs in environment.
4. Use SQLmap to identify & validate SQL injection.
5. Check whether error messages reveal database information.

CIA Impact :

- Confidentiality
- Integrity
- Availability

Mitigation :

- ⇒ Use prepared statements and parameterized query.
- ⇒ Validate input on the server.
- ⇒ Encode output to prevent XSS.
- ⇒ Hide detailed database errors.
- ⇒ Use secure cookies and session management.
- ⇒ Implement CSP, CSRF, protection, and least-privilege database accounts.

Conclusion :

Secure coding, proper validation, output encoding, and strong session controls are the essential.

3. Evil Twin Attack :

An evil twin attack occurs when an attacker creates a fake wi-fi access point, using the same or similar SSID as the legitimate corporate network.

Attack Process:

1. Attacker identifies the company's SSID.
2. A fake access point is created with a similar SSID.
3. Employees connect to the fake network.
4. The attacker can monitor or manipulate traffic that is not properly protected.
5. Fake login pages may be used to collect the credentials.

Kali Linux Tools :

- Aircrack-ng
- Wireshark

Weaknesses :

- ⇒ Shared WPA2-PSK Password.
- ⇒ Lack of individual user authentication.
- ⇒ NO Proper rogue AP monitoring.
- ⇒ Employees may trust SSID's without verification.
- ⇒ Poor network segmentation.

Countermeasures :

- ⇒ Use WPA2-Enterprise or WPA3-Enterprise with 802.1X.
- ⇒ Deploy wireless IDS/WIPS.

- ⇒ Use HTTPS and secure VPN connections.
- ⇒ Train employees to identify suspicious wifi and login pages.

Conclusion:

Strong authentication, wireless monitoring, segmentation, and user awareness can prevent the Evil twin attacks.

4. Wireless to Web application Attack:

The attack begins with weak wifi security and continues with exploitation of weaknesses in the employee management application.

Attack chain:

Weak wifi password → Network access → Reconnaissance → scanning → web application testing → Authentication bypass → Privilege escalation → Data access.

Security frameworks:

1. Wireless:

- * WPA3 - Enterprise / WPA2 - Enterprise.
- * Strong authentication
- * Wireless IDS / WIPS.

2. Network:

- * VLAN Segmentation
- * Firewall and IDS / IPS
- * Network access control.

Web application:

- strong authentication
- Role-based access control
- secure sessions
- Input validation
- Parameterized queries
- Output encoding.

Conclusion:

Wireless, network, and application security must work together to provide defence - in - depth.

5. Wireless Deauthentication Attack:

A deauthentication attack is a wireless Denial-of-Service attack in which forged management frames cause legitimate device to disconnect from an access point.

Attack process:

1. Attacker identifies the target access point.
2. Wireless traffic is monitored.
3. Forged deauthentication frames are transmitted.
4. Clients disconnect from the access point.
5. Repeated attacks cause continuous network disruption.

Kali Linux Analysis:

1. Aircrack-ng
2. Wireshark.

Can analyze captured wireless traffic & identify unusual numbers of deauthentication frames.

Testing should only be performed against authorized laboratory equipment.

Impact :

The attack mainly affects Availability.

- ⇒ Users lose WiFi connectivity.
- ⇒ Online classes and meetings are interrupted.
- ⇒ Employees lose productivity.
- ⇒ Network services become unreliable.
- ⇒ The organization may face operational losses.

Mitigation :

- ⇒ Use WPA3 with protected management frames (PMF).
- ⇒ Deploy wireless IDS/IPS.
- ⇒ Monitor abnormal deauthentication activity.
- ⇒ Use strong wireless authentication.
- ⇒ Keep access points updated.
- ⇒ Maintain continuous wireless monitoring.

Conclusion :

WPA3, PMF, wireless monitoring, IDS/IPS, and proper network configuration can significantly reduce deauthentication attacks.